

Защитник внутреннего контура: путь в информационную безопасность с нуля

Практическое руководство с заданиями на open-source инструментах и с учётом законодательства Республики Узбекистан

Oct 4, 2026 · @Умиджон

Предисловие

Эта книга за 12 месяцев проводит человека без опыта до уровня младшего специалиста по защите внутреннего контура (Blue Team, SOC L1, инженер ИБ). Всё делается на бесплатных open-source инструментах и в рамках законодательства Республики Узбекистан.

Кому подходит книга

- Студентам и выпускникам без опыта в ИТ.
- Системным администраторам и специалистам техподдержки, которые хотят перейти в ИБ.
- Сотрудникам банков, госорганов и компаний Узбекистана, которым поручили «заняться безопасностью».

Что такое «внутренний контур»

Внутренний контур — это всё, что находится за периметром организации: рабочие станции, серверы, Active Directory, внутренние сети и VLAN, базы данных, файловые хранилища и сами сотрудники. Защитник внутреннего контура исходит из того, что атакующий **уже внутри** (через фишинг, флешку, недобросовестного сотрудника или скомпрометированного подрядчика). Его задачи: не дать атакующему развернуться, быстро его заметить и выгнать.

Как читать

1. Читайте главы по порядку: каждая опирается на предыдущую.
2. Каждая глава заканчивается блоком «**Практика**» с тестовыми заданиями трёх уровней: базовый, средний и продвинутый.
3. Ведите **лабораторный журнал**: Markdown-файлы в Git (например, на GitHub или GitLab). Записывайте каждую команду, вывод и вывод для себя. Позже журнал станет вашим портфолио.

4. Ключи и подсказки к заданиям собраны в Приложениях.
5. Нормативные акты меняются. Перед практическим применением проверяйте актуальную редакцию на Национальной базе законодательства lex.uz.

Правила этики (обязательны)

- Атакующие техники отрабатываются **только в своей лаборатории** или при наличии **письменного разрешения** владельца системы.
- Неправомерный доступ к компьютерной информации — уголовное преступление в Узбекистане (см. Главу 1). Фраза «я просто проверял» от ответственности не освобождает.
- Персональные данные, найденные при работе, не копируются, не публикуются и не используются в личных целях.
- Об обнаруженных уязвимостях вы сообщаете владельцу системы или в национальный CERT (UZCERT), а не в соцсети.

Дорожная карта

Месяц	Этап	Главы	Результат
1	Право и фундамент	1-2	Понимаете законы, сети, ОС
2-3	Администрирование	3	Уверенно работаете в Linux и Windows
3	Теория ИБ	4	Говорите на языке рисков и АТТ&СК
4	Лаборатория	5	Рабочий стенд из 6-8 VM
5	Активы и уязвимости	6	Инвентаризация и сканирование
6	Сеть	7	Сегментация, межсетевой экран, IDS
7	Идентичность	8	Защищённый Active Directory
8	Конечные точки	9	Харднинг и EDR-агенты
9	Мониторинг	10	Свой SIEM и правила обнаружения
10	Инциденты	11	Проведённое расследование

Месяц	Этап	Главы	Результат
11	Данные и документы	12–13	Пакет политик ИБ
12	Карьера и итоговый проект	14, Приложения	Портфолио и резюме

Минимальное железо: ноутбук или ПК с 16 ГБ ОЗУ (лучше 32 ГБ), SSD на 500 ГБ и процессором с поддержкой виртуализации. Время: 10–15 часов в неделю.

Глава 1. Правовая база Узбекистана для специалиста по ИБ

Защитник должен знать пять групп норм: закон о кибербезопасности, закон о персональных данных, законы об информатизации и тайнах, трудовое право и уголовную ответственность. Ниже — что из них влияет на ежедневную работу.

Важно. Эта глава — учебный обзор, а не юридическая консультация. Номера статей и редакции меняются. Перед тем как ссылаться на норму в рабочем документе, откройте актуальный текст на lex.uz и согласуйте его с юристом организации.

1.1. Ключевые акты

Акт	Что регулирует	Что значит для защитника
Закон «О кибербезопасности» (№ ЗРУ-764, 2022)	Уполномоченный орган, объекты критической информационной инфраструктуры (КИИ), инциденты, аудит	Узнать, относится ли ваша организация к КИИ; выстроить процесс уведомления об инцидентах
Закон «О персональных данных» (№ ЗРУ-547, 2019)	Сбор, обработка, защита, локализация ПДн граждан РУз	Защита баз ПДн, хранение на территории Узбекистана, регистрация баз, согласия
Закон «Об информатизации» (2003)	Информационные ресурсы и системы, обязанность их защиты	Основание для внутренних политик ИБ

Акт	Что регулирует	Что значит для защитника
Закон «О принципах и гарантиях свободы информации» (2002)	Информационная безопасность личности, общества, государства	Разграничение открытой и конфиденциальной информации
Закон «О коммерческой тайне» (2014)	Режим коммерческой тайны	Перечень сведений, грифы, соглашения о неразглашении (NDA)
Закон «О защите государственных секретов»	Гостайна	Применяется только в организациях с допуском; там действуют особые требования
Законы об электронной цифровой подписи и электронном документообороте	ЭЦП, юридическая сила электронных документов	Защита ключей ЭЦП сотрудников, целостность документооборота
Трудовой кодекс (новая редакция, действует с 2023 г.)	Права и обязанности работника и работодателя, локальные акты	Ознакомление с политиками под подпись, правомерность мониторинга
Уголовный кодекс, глава «Преступления в сфере информационных технологий» (ст. 278 ¹ и следующие)	Несанкционированный доступ, модификация информации, компьютерный саботаж, вредоносные программы	Границы допустимого при тестировании; квалификация действий нарушителя
Кодекс об административной ответственности	Штрафы, в том числе за нарушение законодательства о персональных данных и правил информатизации	Риски для организации и должностных лиц

1.2. Закон «О кибербезопасности»: что знать

- **Уполномоченный государственный орган** в сфере кибербезопасности — Служба государственной безопасности (СГБ). Практическую работу ведёт ГУП «Центр кибербезопасности», в состав которого входит национальная

служба реагирования на инциденты UZCERT (uzcert.uz).

- **Объекты КИИ** — системы, нарушение работы которых влияет на безопасность государства: энергетика, транспорт, банки, связь, здравоохранение и др. Для них действуют дополнительные требования: аудит ИБ, согласование средств защиты, уведомление об инцидентах.
- **Инциденты.** Закон требует сообщать об инцидентах кибербезопасности уполномоченным органам. Сроки и форму уточняйте по подзаконным актам и внутренним требованиям регулятора отрасли (для банков — Центральный банк). Ваша задача — заранее вписать этот шаг в план реагирования (Глава 11).
- **Статус специалиста.** Работы по аудиту ИБ и тестированию на проникновение для сторонних организаций могут требовать лицензии или аккредитации. Внутренний защитник работает на своём работодателе по должностной инструкции и приказу руководителя.

1.3. Персональные данные: четыре практических правила

1. **Локализация.** Поправки 2021 года (статья 27¹) требуют обрабатывать ПДн граждан Узбекистана с помощью технических средств на территории республики, в базах, зарегистрированных в Государственном реестре. Для защитника это значит: прежде чем ставить облачный SIEM или бэкап за рубежом, проверьте, не попадут ли туда ПДн. Это ещё одна причина выбирать self-hosted open-source.
2. **Реестр баз.** Реестр баз персональных данных ведёт уполномоченный орган (Государственный центр персонализации; актуальный орган уточняйте). Знайте, какие базы вашей организации там зарегистрированы.
3. **Минимизация.** Собирайте в логах и тикетах только нужные данные; не пересылайте выгрузки с ПДн в личные мессенджеры.
4. **Защита и утечки.** Оператор обязан принимать правовые, организационные и технические меры защиты. При утечке действует ваш план реагирования и порядок уведомления уполномоченного органа и субъектов данных.

1.4. Мониторинг сотрудников без нарушения закона

Конституция РУз гарантирует тайну переписки и неприкосновенность частной жизни. Поэтому любой контроль в контуре строится на трёх опорах:

- **Локальный акт** — «Политика допустимого использования ИТ-ресурсов», утверждённая приказом. В ней прямо написано, что корпоративные устройства и почта предназначены для работы и что их использование журналируется.

- **Подпись сотрудника** — лист ознакомления и согласие на обработку ПДн для целей ИБ.
- **Соразмерность** — вы собираете события безопасности (входы, запуск процессов, сетевые соединения), а не читаете личную переписку. Доступ к содержимому — только в рамках расследования, по распоряжению руководства и с участием юриста.

1.5. Криптография и сертификация

- Разработка, производство, реализация и ввоз криптографических средств в Узбекистане лицензируются и контролируются СГБ. Использование шифрования для собственных нужд (TLS, BitLocker/LUKS, SSH) — обычная практика в коммерческих организациях.
- Для госорганов, КИИ и защиты гостайны требуются **сертифицированные** средства защиты и национальные алгоритмы (стандарты O'z DSt 1092 — ЭЦП, O'z DSt 1105 — шифрование данных). Здесь open-source дополняет, но не заменяет сертифицированные решения.
- Международные стандарты приняты как национальные: O'z DSt ISO/IEC 27001 (система менеджмента ИБ), O'z DSt ISO/IEC 27002 (меры защиты). Их структура лежит в основе Главы 13.

1.6. Граница между защитой и преступлением

Действие	Законно?
Сканировать свою домашнюю лабораторию	Да
Сканировать сеть работодателя по приказу и в рамках должности	Да
Сканировать сеть работодателя «из интереса» без разрешения	Нет: дисциплинарная и, возможно, уголовная ответственность
Сканировать чужие сайты и серверы	Нет
Использовать чужие утёкшие пароли для входа	Нет, даже для «проверки»
Проверять хэши паролей своего AD на сложность по согласованному плану	Да, при письменном разрешении и защищённом хранении результатов
Распространять вредоносные образцы вне закрытой лаборатории	Нет

Шаблон письменного разрешения («разрешение на работы») должен содержать: кто разрешает (должность, подпись), кому, какие системы и диапазоны IP, какие действия допустимы и запрещены, сроки, контакт для экстренной остановки и порядок обращения с найденными данными.

Практика к Главе 1

- ☐ **Базовое.** Найдите на lex.uz актуальные тексты законов «О кибербезопасности» и «О персональных данных». Выпишите в журнал дату последней редакции и все термины из статьи «Основные понятия».
- ☐ **Базовое.** Найдите в Уголовном кодексе все статьи главы о преступлениях в сфере ИТ. Для каждой напишите один пример из жизни компании.
- ☐ **Среднее.** Составьте шаблон «Разрешение на проведение внутреннего сканирования уязвимостей» (1 страница) по пунктам из 1.6.
- ☐ **Среднее.** Опишите для выдуманного частного банка в Ташкенте: какие его системы могут быть объектами КИИ, где хранятся ПДн, кто регулятор.
- ☐ **Продвинутое.** Напишите черновик «Политики допустимого использования ИТ-ресурсов» на 2–3 страницы с разделом о мониторинге и ссылками на нормы. Покажите его знакомому юристу.

Глава 2. Фундамент: как устроены компьютеры, ОС и сети

Нельзя защитить то, чего не понимаешь. 80% ошибок начинающих защитников — это пробелы в сетях и ОС, а не в «хакерских» знаниях. Эта глава занимает 3–4 недели.

2.1. Компьютер и операционная система

- **Процессор, память, диск.** Программа лежит на диске, загружается в память и выполняется процессором. Вредоносное ПО может жить только в памяти (fileless) — поэтому в Главе 11 мы снимаем дампы ОЗУ.
- **Ядро и пользовательское пространство.** Ядро управляет железом, программы обращаются к нему через системные вызовы. EDR-агенты и Sysmon наблюдают именно за ними.
- **Процессы и потоки.** У каждого процесса есть PID, родитель (PPID), пользователь и командная строка. Цепочка «родитель → ребёнок» — главный инструмент аналитика: `winword.exe → powershell.exe` почти всегда плохой знак.
- **Пользователи и права.** root/SYSTEM/Администратор может всё. Принцип наименьших привилегий: работать под обычной учётной записью.

- **Файловые системы.** NTFS (права ACL, альтернативные потоки данных, журнал \$MFT), ext4 (права rwx, владелец, группа).

2.2. Сети: модель OSI и TCP/IP

Уровень OSI	Протоколы	Типичные атаки внутри контура	Защита
7 Прикладной	HTTP, DNS, SMB, LDAP, Kerberos, RDP	Подбор паролей, Kerberoasting, DNS-туннели	Журналирование, MFA, фильтрация
4 Транспортный	TCP, UDP	Сканирование портов	Межсетевой экран, IDS
3 Сетевой	IP, ICMP	Подмена адреса, движение между сегментами	Сегментация, ACL
2 Канальный	Ethernet, ARP, VLAN 802.1Q	ARP-спуфинг, VLAN hopping, поддельный DHCP	Port security, DHCP snooping, DAI, 802.1X
1 Физический	Кабель, Wi-Fi	Чужое устройство в розетке	Физический доступ, отключение пустых портов

Что нужно знать наизусть:

- IPv4-адресация, маски и CIDR (посчитать в уме, сколько хостов в /26). Частные диапазоны: 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16.
- Трёхстороннее рукопожатие TCP (SYN, SYN-ACK, ACK) и флаги RST, FIN.
- Порты: 22 SSH, 25 SMTP, 53 DNS, 80/443 HTTP(S), 88 Kerberos, 135 RPC, 139/445 SMB, 389/636 LDAP(S), 3389 RDP, 5985/5986 WinRM.
- Как работают DHCP, DNS (рекурсия, типы записей A, AAAA, CNAME, MX, SRV, TXT, PTR), NAT и маршрутизация.
- VLAN, trunk/access-порты, маршрутизация между VLAN.

2.3. Инструменты этой главы (все бесплатные)

Инструмент	Зачем
Wireshark / tshark	Захват и разбор трафика

Инструмент	Зачем
tcpdump	Захват трафика на серверах без графики
Nmap	Обнаружение хостов и портов (только в своей сети!)
GNS3 или Containerlab	Эмуляция коммутаторов и маршрутизаторов
ipcalc	Расчёт подсетей

2.4. Пошаговая инструкция: первый захват трафика

1. Установите Wireshark с [wireshark.org](https://www.wireshark.org).
2. Выберите свой сетевой интерфейс и нажмите «Start».
3. В браузере откройте `http://neverssl.com`, затем остановите захват.
4. Примените фильтры по очереди: `dns`, `tcp.flags.syn==1 && tcp.flags.ack==0`, `http.request`, `arp`.
5. Найдите DNS-запрос, рукопожатие TCP и HTTP-запрос GET. Через «Follow → TCP Stream» посмотрите содержимое.
6. Вывод для журнала: всё, что идёт по HTTP без S, видно целиком любому, кто видит трафик.

Аналог в консоли Linux:

```
sudo tcpdump -i eth0 -nn -c 100 port 53
sudo tcpdump -i eth0 -w capture.pcap # сохранить для Wireshark
```

2.5. Рекомендуемые бесплатные курсы

- Cisco Networking Academy: «Networking Basics» и «Introduction to Cybersecurity» (есть на русском; академии работают при вузах Узбекистана, в том числе ТУИТ им. Аль-Хорезми).
- «Professor Messer» — бесплатные видеокурсы CompTIA Network+ и Security+.
- Книга В. и Н. Олифер «Компьютерные сети. Принципы, технологии, протоколы».

Практика к Главе 2

- ☐ **Базовое.** Для сети 10.20.30.0/26 найдите адрес сети, широковещательный адрес и число хостов. Поделите 192.168.10.0/24 на 4 равные подсети.
- ☐ **Базовое.** Назовите по памяти порты 15 сервисов из 2.2 и протокол (TCP/UDP).

- ☐ **Среднее.** Захватите трафик входа на сайт по HTTPS и найдите в нём имя сайта (поле SNI в TLS Client Hello). Объясните, почему его видно, а пароль — нет.
- ☐ **Среднее.** Скачайте учебный рсар с malware-traffic-analysis.net (раздел Training Exercises) и определите IP, имя хоста и MAC заражённой машины. Открывайте файлы только в изолированной VM.
- ☐ **Продвинутое.** В GNS3 соберите сеть из коммутатора, маршрутизатора и двух VLAN («Бухгалтерия», «ИТ»). Добейтесь, чтобы ИТ видела Бухгалтерию, а наоборот — нет.

Глава 3. Администрирование Linux и Windows для защитника

Защитник должен администрировать не хуже сисадмина: в типичной организации Узбекистана рабочие места на Windows в домене Active Directory, а серверы и средства защиты — на Linux. Цель главы — уверенная работа в командной строке обеих систем. Срок: 6–8 недель.

3.1. Linux: обязательный минимум

Рабочий дистрибутив: **Ubuntu Server 24.04 LTS** или **Debian 12**. Для инструментов аналитика пригодится Kali Linux, но не начинайте с него.

Тема	Команды	Зачем защитнику
Файлы и поиск	<code>ls -la</code> , <code>find / -perm -4000 2>/dev/null</code> , <code>grep -r</code>	Поиск SUID-файлов и подозрительных строк
Права	<code>chmod</code> , <code>chown</code> , <code>umask</code> , <code>getfacl</code>	Исправление избыточных прав
Пользователи	<code>id</code> , <code>sudo -l</code> , <code>/etc/passwd</code> , <code>/etc/shadow</code> , <code>lastlog</code> , <code>last</code>	Кто есть в системе и когда заходил
Процессы	<code>ps auxf</code> , <code>top</code> , <code>lsof -p PID</code> , <code>kill</code>	Поиск чужих процессов
Сеть	<code>ip a</code> , <code>ss -tulpn</code> , <code>ip route</code> , <code>dig</code> , <code>curl</code>	Какие порты слушаются и кем
Службы	<code>systemctl list-units --type=service</code> , <code>systemctl list-timers</code>	Закрепление злоумышленника

Тема	Команды	Зачем защитнику
Планировщик	<code>crontab -l</code> , <code>/etc/cron.*</code>	Закрепление злоумышленника
Журналы	<code>journalctl -u ssh</code> , <code>/var/log/auth.log</code>	Поиск подбора паролей
Пакеты	<code>apt update && apt upgrade</code> , <code>unattended-upgrades</code>	Устранение уязвимостей
Межсетевой экран	<code>ufw</code> , <code>nftables</code>	Ограничение доступа к серверу

Пример: кто подбирает пароли к SSH?

```
grep "Failed password" /var/log/auth.log \
  | awk '{print $(NF-3)}' | sort | uniq -c | sort -rn | head
```

Минимальное укрепление SSH (`/etc/ssh/sshd_config`):

```
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
AllowGroups ssh-admins
```

После изменений: `sudo sshd -t && sudo systemctl reload ssh`. Не закрывайте текущую сессию, пока не проверите вход по ключу в новом окне.

3.2. Bash-скрипты

Научитесь писать скрипты с переменными, циклами, условиями и конвейерами. Инструменты: `awk`, `sed`, `cut`, `sort`, `uniq`, `jq` (для JSON-логов). Игра [OverTheWire Bandit](#) — лучший бесплатный тренажёр (пройдите уровни 0–20).

3.3. Windows: обязательный минимум

Для лаборатории Microsoft бесплатно даёт ознакомительные версии Windows Server (180 дней) и Windows 11 Enterprise (90 дней) в Evaluation Center. Это легальный способ учиться — не используйте взломанные сборки: в них часто защиты трояны, а использование нелицензионного ПО нарушает авторское право.

Тема	Инструмент / команда	Зачем
Процессы	<code>Get-Process</code> , Process Explorer (Sysinternals)	Дерево процессов, подписи
Автозагрузка	Autoruns (Sysinternals)	Поиск закрепления
Сеть	<code>Get-NetTCPConnection</code> , <code>netstat -ano</code> , TCPView	Кто куда подключён
Журналы	<code>Get-WinEvent</code> , Event Viewer	Расследования
Службы и задачи	<code>Get-Service</code> , <code>Get-ScheduledTask</code>	Закрепление
Пользователи	<code>Get-LocalUser</code> , <code>net localgroup administrators</code>	Лишние админы
Политики	<code>gpresult /r</code> , <code>gpedit.msc</code> , <code>secpol.msc</code>	Проверка настроек
Реестр	<code>reg query</code> , <code>Get-ItemProperty</code>	Ключи Run, настройки безопасности

Ключевые события журнала Security, которые нужно знать наизусть:

Event ID	Событие
4624 / 4625	Успешный / неуспешный вход (смотрите Logon Type: 2 локальный, 3 сетевой, 10 RDP)
4672	Вход с привилегиями администратора
4688	Создание процесса (включите запись командной строки)
4720 / 4726	Создана / удалена учётная запись
4728 / 4732 / 4756	Добавление в глобальную / локальную / универсальную группу
4740	Учётная запись заблокирована
4768 / 4769	Запрос билета Kerberos TGT / TGS
4698	Создана запланированная задача
7045 (System)	Установлена новая служба

Event ID	Событие
1102	Очищен журнал безопасности — красный флаг

Пример PowerShell: неудачные входы за сутки

```
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-Date).AddDays(-1)} |
  ForEach-Object { $_.Properties[5].Value } |
  Group-Object | Sort-Object Count -Descending | Select-Object -First 10
```

3.4. Скриптовый язык: Python

Python нужен для разбора логов, автоматизации и работы с API средств защиты. Минимум: типы данных, функции, работа с файлами, модули `re`, `json`, `csv`, `requests`, `ipaddress`.

```
import re, collections
ips = collections.Counter()
for line in open('/var/log/auth.log', encoding='utf-8', errors='ignore'):
    m = re.search(r'Failed password .* from (\d+\.\d+\.\d+\.\d+)', line)
    if m:
        ips[m.group(1)] += 1
for ip, n in ips.most_common(10):
    print(f'{ip}\t{n}')
```

Практика к Главе 3

- ☐ **Базовое.** Пройдите OverTheWire Bandit до 20 уровня. Запишите в журнал команду-решение каждого уровня (но не пароли).
- ☐ **Базовое.** На Ubuntu Server создайте пользователя `analyst` без `sudo`, группы `ssh-admins`, настройте вход по ключу и запретите вход по паролю.
- ☐ **Среднее.** Напишите `bash`-скрипт `triage.sh`, который собирает в один файл: список пользователей с UID 0, слушающие порты, `crontab` всех пользователей, файлы, изменённые в `/etc` за последние 24 часа.
- ☐ **Среднее.** На Windows включите аудит создания процессов и запись командной строки в 4688. Запустите `whoami /all` и найдите это событие через PowerShell.
- ☐ **Продвинутое.** Напишите Python-скрипт, который читает `auth.log` и выводит IP, с которых было более 10 неудачных попыток и затем успешный вход (признак удачного подбора).

Глава 4. Основы ИБ: триада, риски, модели угроз, MITRE ATT&CK

Защитник думает не «какой инструмент поставить», а «какой риск я снижаю». Эта глава даёт язык, на котором вы будете говорить с руководством, аудиторами и коллегами.

4.1. Базовые понятия

- **Триада CIA:** конфиденциальность (данные видят только те, кому можно), целостность (данные не искажены), доступность (система работает, когда нужна). Шифровальщик бьёт по доступности, утечка — по конфиденциальности, подмена реквизитов — по целостности.
- **AAA:** аутентификация (кто ты), авторизация (что тебе можно), учёт (что ты сделал).
- **Актив, угроза, уязвимость, риск.** Риск = вероятность × ущерб. Уязвимость без угрозы и ценного актива — не риск.
- **Эшелонированная защита (defense in depth):** несколько независимых слоёв, чтобы падение одного не давало доступа ко всему.
- **Наименьшие привилегии и разделение обязанностей.**
- **Zero Trust:** никому не доверять только потому, что он «внутри сети». Для защитника внутреннего контура это главный принцип.

4.2. Как атакуют внутренний контур

Типичная цепочка атаки на организацию выглядит так:

1. **Первоначальный доступ** — фишинговое письмо с вложением (часто под видом налоговой, суда, банка), уязвимый публичный сервис, украденный пароль VPN, заражённая флешка.
2. **Выполнение** — запуск макроса, PowerShell, скрипта.
3. **Закрепление** — задача в планировщике, служба, ключ Run.
4. **Повышение привилегий и кража учётных данных** — дампы LSASS, Kerberoasting, пароли в файлах и GPP.
5. **Разведка внутри** — изучение AD (BloodHound), сканирование сети.
6. **Горизонтальное перемещение** — RDP, SMB/PsExec, WinRM с украденными учётными данными.
7. **Захват домена** — права Domain Admin, DCSync.
8. **Достижение цели** — кража данных, шифрование, мошеннические платежи.

На каждом шаге у защитника есть шанс помешать или заметить. Чем раньше — тем дешевле инцидент.

4.3. MITRE ATT&CK — главный справочник

[MITRE ATT&CK](#) — бесплатная база тактик (зачем) и техник (как) реальных атакующих. Каждая техника имеет номер: T1059.001 — PowerShell, T1003.001 — дампы LSASS, T1558.003 — Kerberoasting, T1021.001 — RDP. Правила обнаружения и отчёты вы будете привязывать к этим номерам.

Инструменты: **ATT&CK Navigator** (раскрашивает матрицу — что вы видите, а что нет), **MITRE D3FEND** (каталог защитных мер), **Atomic Red Team** (тесты для проверки обнаружения, Глава 10).

4.4. Оценка рисков на практике

Простая качественная методика (по мотивам ISO/IEC 27005):

1. Составьте список активов и их владельцев.
2. Для каждого актива оцените ущерб по C, I, A по шкале 1–5.
3. Перечислите угрозы и оцените вероятность 1–5 с учётом существующих мер.
4. Риск = ущерб × вероятность (1–25). 15–25 — высокий, 8–14 — средний, 1–7 — низкий.
5. Для каждого риска выберите решение: снизить, передать (страхование, подрядчик), избежать (отказаться от процесса), принять (подпись руководителя).

Пример строки реестра рисков:

Актив	Угроза	Уязвимость	Ущерб	Вероятность	Риск	Мера
Сервер 1С бухгалтерии	Шифровальщик	RDP открыт всей сети, нет офлайн-бэкапа	5	4	20 (высокий)	Ограничить RDP, бэкап по правилу 3-2-1, EDR

4.5. Модель угроз

Модель угроз отвечает на четыре вопроса: что мы защищаем, от кого, как именно на нас нападут и что мы делаем. Для узбекистанской организации типичные нарушители:

- финансово мотивированные группы (шифровальщики, кража денег через дистанционное банковское обслуживание);

- недобросовестные или увольняющиеся сотрудники (продажа баз клиентов — один из самых частых сценариев);
- небрежные сотрудники (передача документов через личный Telegram, слабые пароли);
- подрядчики с удалённым доступом (интеграторы 1С, обслуживание АБС);
- целевые (APT) группировки — для госорганов и КИИ.

Для приложений удобна методика **STRIDE** (подмена личности, изменение, отказ от действий, раскрытие информации, отказ в обслуживании, повышение привилегий) и бесплатный инструмент **OWASP Threat Dragon**.

4.6. Фреймворки, которые стоит знать

Фреймворк	Для чего
ISO/IEC 27001 / 27002 (O'z DSt)	Система менеджмента ИБ и 93 меры защиты (редакция 2022)
CIS Critical Security Controls v8	18 практических мер с приоритетами (IG1 — минимум для любой организации)
NIST Cybersecurity Framework 2.0	Функции Govern, Identify, Protect, Detect, Respond, Recover
CIS Benchmarks	Конкретные настройки для Windows, Linux, СУБД
MITRE ATT&CK / D3FEND	Атаки и защитные меры

Для начинающего лучшая опора — **CIS Controls IG1**: если вы внедриli 56 его мер, вы уже защищены лучше большинства организаций.

Практика к Главе 4

- ☐ **Базовое.** Для каждого из 8 шагов из 4.2 найдите в ATT&CK тактику и две техники с номерами.
- ☐ **Базовое.** Приведите по два примера инцидентов, нарушающих C, I и A.
- ☐ **Среднее.** Составьте реестр из 10 рисков для выдуманной компании «ООО Самарканд Текстиль» (200 сотрудников, AD, 1С, файловый сервер, интернет-магазин) по форме из 4.4.
- ☐ **Среднее.** Откройте CIS Controls v8 и выпишите все меры IG1. Отметьте, какие из них закрывают ваши 10 рисков.

- ☐
- Продвинутое.** В ATT&CK Navigator создайте слой с техниками одной известной группировки шифровальщиков (раздел Groups) и экспортируйте картинку в журнал.

Глава 5. Домашняя лаборатория на open-source

Лаборатория — это уменьшенная копия корпоративной сети из 6–8 виртуальных машин, где вы легально атакуете и защищаете. Все следующие главы выполняются на ней. Срок сборки: 2–3 недели.

5.1. Гипервизор

Вариант	Когда выбирать
Proxmox VE (open-source)	Есть отдельный ПК или старый сервер. Лучший вариант: так работают и многие компании
VirtualBox (open-source)	Только один ноутбук, нужно начать сегодня
KVM + virt-manager	У вас уже Linux на ноутбуке

5.2. Состав стенда

Учебная компания: «**ООО Учебный Банк**», домен `lab.local`.

ВМ	ОС	Роль	Сегмент	ОЗУ
FW01	OPNsense	Межсетевой экран и маршрутизатор между сегментами, Suricata	Все	2 ГБ
DC01	Windows Server 2022 (eval)	Контроллер домена, DNS	Серверы 10.10.10.0/24	4 ГБ
SRV01	Ubuntu Server 24.04	Файловый (Samba) и веб-сервер	Серверы 10.10.10.0/24	2 ГБ
WS01	Windows 11 (eval)	Рабочее место бухгалтера	Пользователи 10.10.20.0/24	4 ГБ
WS02	Ubuntu Desktop	Рабочее место разработчика	Пользователи 10.10.20.0/24	2 ГБ

ВМ	ОС	Роль	Сегмент	ОЗУ
SIEM01	Ubuntu Server + Wazuh	SIEM, XDR, управление агентами	Управление 10.10.99.0/24	8 ГБ
ATK01	Kali Linux	«Атакующий» для проверки защиты	Пользователи (имитация заражённого ПК)	2–4 ГБ
SO01 (опционально)	Security Onion	Анализ сетевого трафика (Zeek, Suricata)	Управление + SPAN	16 ГБ

Если памяти мало (16 ГБ), включайте ВМ по частям: DC01 + WS01 + SIEM01 — это минимум для большинства заданий.

5.3. Пошаговая сборка

- 1. Изоляция.** В гипервизоре создайте три внутренние сети (Internal Network / Linux bridge без физического интерфейса): LAB_SRV, LAB_USR, LAB_MGMT. В интернет смотрит только FW01 (через NAT). Так учебные атаки никогда не уйдут в домашнюю сеть или к провайдеру.
- 2. OPNsense.** Установите с 4 интерфейсами (WAN + 3 внутренних). Включите DHCP в сегменте пользователей. На первом этапе разрешите всё между сегментами — сегментацию сделаем в Главе 7.
- 3. DC01.** Установите Windows Server, задайте статический IP 10.10.10.10, добавьте роль AD DS и создайте лес lab.local:

```
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
Install-ADDSForest -DomainName "lab.local" -InstallDNS
```

- 4. Наполнение AD.** Создайте OU «Бухгалтерия», «ИТ», «Кредитный отдел» и 30–50 пользователей скриптом PowerShell (New-ADUser в цикле из CSV). Намеренно заложите типичные ошибки: сервисную учётную запись со SPN и слабым паролем, пользователя в Domain Admins «временно», пароль в описании учётной записи. В Главе 8 вы их найдёте и исправите. Альтернатива — open-source скрипты BadBlood или vulnerable-AD, которые делают это автоматически.
- 5. WS01.** Установите Windows 11, введите в домен, войдите пользователем из «Бухгалтерии».
- 6. SRV01.** Ubuntu Server: Samba-шара \\srv01\docs, nginx с простой страницей. По желанию — ввод в домен через realmd / sssd.

7. **SIEM01.** Установите Wazuh одной командой из официальной документации (Quickstart, all-in-one). Подробно — в Главе 10.
8. **АТК01.** Kali Linux в сегменте пользователей. Он изображает компьютер, который уже захвачен через фишинг.
9. **Снимки.** Сделайте snapshot всех VM в чистом состоянии — вы будете часто к ним возвращаться.
10. **Документация.** Нарисуйте схему сети в draw.io (diagrams.net) и положите её в журнал.

5.4. Готовые альтернативы

- **DetectionLab / Splunk Attack Range / GOAD (Game of Active Directory)** — open-source проекты, разворачивающие готовые лаборатории через Vagrant/Ansible. GOAD особенно хорош для изучения атак на AD, но требует 32+ ГБ ОЗУ.
- **Онлайн-платформы:** TryHackMe (SOC Level 1, Cyber Defense), Blue Team Labs Online, CyberDefenders, LetsDefend. Полезны, когда нет мощного железа; часть заданий бесплатна.

5.5. Правила безопасности лаборатории

- Никогда не подключайте лабораторию к рабочей сети работодателя.
- Образцы вредоносного ПО — только в отдельной VM без сети, в заархивированном виде с паролем `infected`.
- Используйте в лаборатории только выдуманные персональные данные (генератор Faker для Python), никогда настоящие базы клиентов.

Практика к Главе 5

- ☐ **Базовое.** Разверните FW01, DC01, WS01. Проверьте: WS01 входит в домен, `nslookup dc01.lab.local` работает, из WS01 есть интернет через FW01.
- ☐ **Базовое.** Создайте snapshot всех VM и попрактикуйтесь в откате.
- ☐ **Среднее.** Напишите PowerShell-скрипт, создающий пользователей из CSV (ФИО латиницей, отдел, должность) и раскладывающий их по OU.
- ☐ **Среднее.** Добавьте SRV01 и SIEM01, нарисуйте схему сети с IP-адресами и ролями.
- ☐ **Продвинутое.** Опишите всю лабораторию как код (Vagrant или Terraform + Ansible для Proxmox), чтобы пересобрать её одной командой. Опубликуйте в своём GitHub — это сильный пункт портфолио.

Глава 6. Инвентаризация активов и управление уязвимостями

Первые две меры CIS Controls — инвентаризация устройств и ПО. Нельзя защитить сервер, о котором не знаешь: в реальных инцидентах атакующие часто заходят через забытый тестовый сервер или старую камеру видеонаблюдения.

6.1. Инвентаризация: что и чем

Задача	Open-source инструмент
Учёт оборудования и ПО (CMDB)	GLPI (+ GLPI Agent), Snipe-IT, NetBox (для сетей и IP-адресов)
Активное обнаружение устройств	Nmap, netdisco
Пассивное обнаружение (по трафику)	Zeek (логи <code>conn.log</code> , <code>dhcp.log</code> , <code>software.log</code>), arpswatch
Инвентаризация ПО на хостах	osquery, модуль Syscollector в Wazuh
Инвентаризация учётных записей AD	PowerShell (<code>Get-ADUser</code> , <code>Get-ADComputer</code>), PingCastle (бесплатен для аудита собственной организации)

Минимальные поля карточки актива: имя, IP/MAC, сегмент, ОС и версия, владелец (человек и отдел), критичность (1–3), наличие персональных данных, агент SIEM/EDR установлен (да/нет), дата последнего обновления.

Примеры Nmap для инвентаризации (только в своих сетях и по разрешению):

```
nmap -sn 10.10.0.0/16 -oA discovery # кто жив
nmap -sV -O --top-ports 1000 10.10.10.0/24 -oA services # сервисы и версии
nmap -p 445 --script smb-protocols 10.10.0.0/16 # где ещё жив SMBv1
```

Сравнивайте результаты сканирования с CMDB раз в неделю (`ndiff old.xml new.xml`): каждое неизвестное устройство — либо ошибка учёта, либо инцидент.

6.2. Сканирование уязвимостей

Инструмент	Что сканирует
Greenbone / OpenVAS (Community Edition)	Сетевые сервисы, аутентифицированные проверки ОС

Инструмент	Что сканирует
Wazuh Vulnerability Detection	Установленное ПО на хостах с агентами
Nuclei	Веб-сервисы и типичные ошибки конфигурации
Trivy	Образы контейнеров, файловые системы, IaC
Lynis	Аудит настроек Linux
testssl.sh	Настройки TLS

Установка Greenbone Community Edition — проще всего через официальный Docker Compose из документации Greenbone. После запуска дождитесь синхронизации фидов (до нескольких часов), создайте Target → Task → запустите.

Аутентифицированное сканирование (с учётной записью SSH/SMB) находит в 5–10 раз больше уязвимостей, чем внешнее. Заведите для него отдельную учётную запись, ограничьте её вход только с IP сканера и мониторьте её использование.

6.3. Приоритизация: не всё красное срочно

Оценка CVSS говорит о тяжести, а не о риске для вас. Приоритет ставьте по четырём факторам:

1. Уязвимость есть в каталоге **CISA KEV** (известные эксплуатируемые уязвимости) — её уже используют в атаках.
2. Вероятность эксплуатации по **EPSS** выше 10%.
3. Критичность актива (контроллер домена, АБС, сервер с ПДн).
4. Достижимость (из сегмента пользователей или только из изолированного сегмента).

Пример SLA на устранение (утвердите приказом):

Приоритет	Критерий	Срок
P1	В KEV или критичная на критичном активе	72 часа
P2	CVSS ≥ 7 на доступном из сети сервисе	14 дней
P3	CVSS 4–6.9	30 дней

Приоритет	Критерий	Срок
P4	Остальное	90 дней или принятие риска

6.4. Цикл управления уязвимостями

1. Обнаружить (сканирование раз в неделю + подписка на бюллетени вендоров и UZCERT).
2. Оценить и присвоить приоритет.
3. Назначить исполнителя: защитник находит, сисадмин устраняет. Тикеты — в GLPI, Redmine или DefectDojo (open-source платформа для учёта уязвимостей).
4. Устранить: патч, изменение конфигурации или компенсирующая мера (изоляция).
5. Проверить повторным сканированием.
6. Отчитаться: доля активов под сканированием, среднее время устранения, число просроченных P1/P2.

Практика к Главе 6

- ☐ **Базовое.** Установите GLPI на SRV01, разверните GLPI Agent на WS01 и WS02 и убедитесь, что карточки заполнились автоматически.
- ☐ **Базовое.** Сделайте Nmap-обнаружение всех сегментов лаборатории и сравните с GLPI.
- ☐ **Среднее.** Установите на SRV01 устаревшую версию любого веб-приложения (или поднимите в Docker образы из проекта Vulhub). Просканируйте Greenbone и Nuclei, сравните результаты.
- ☐ **Среднее.** Для найденных уязвимостей проверьте наличие в CISA KEV и значение EPSS, присвойте P1–P4.
- ☐ **Продвинутое.** Напишите Python-скрипт: берёт CSV-отчёт Greenbone, добавляет колонки «в KEV» и «EPSS» из открытых источников и сортирует по приоритету.

Глава 7. Сетевая безопасность внутреннего контура

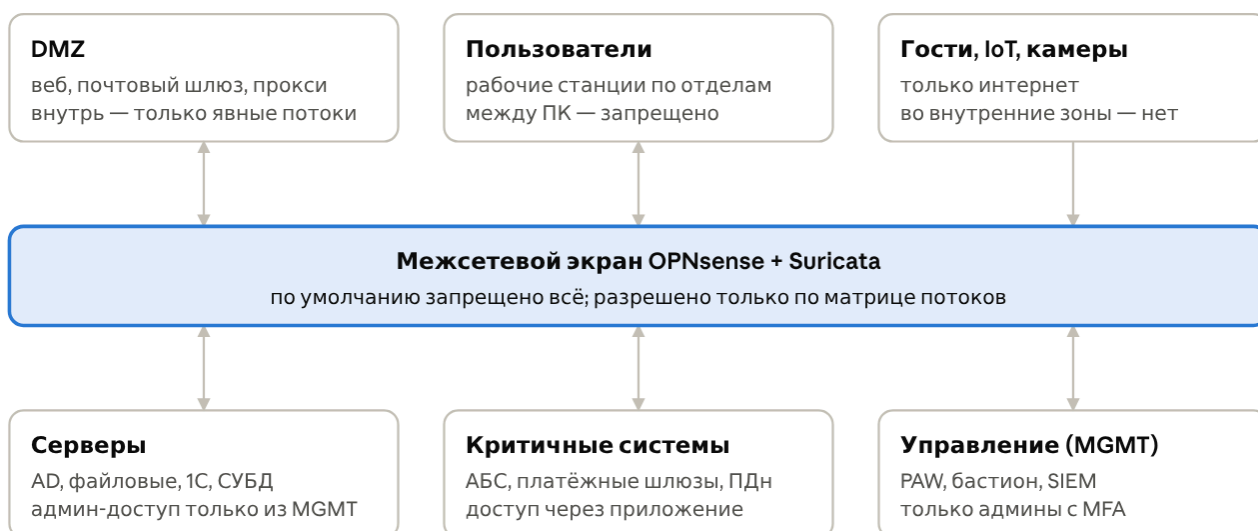
Плоская сеть, где компьютер бухгалтера видит контроллер домена по всем портам, — подарок для шифровальщика. Цель главы: разделить сеть на зоны, разрешить между ними только нужное и видеть всё, что пересекает границы.

7.1. Сегментация по зонам

Зона	Что внутри	Кому разрешён доступ
Пользователи (по отделам)	Рабочие станции	К серверам — только к нужным портам (DNS, Kerberos, LDAP, SMB к файловому, HTTPS к приложениям). Между рабочими станциями — ничего
Серверы	AD, файловые, 1С, СУБД	Из зоны пользователей по белому списку; администрирование — только из зоны управления
Критичные системы	АБС, платёжные шлюзы, базы ПДн	Отдельный сегмент, доступ через терминальные серверы или приложение
Управление (MGMT)	Админские рабочие станции (PAW), бастион, SIEM, интерфейсы iLO/IPMI	Только администраторы, с MFA
DMZ	Публичные сервисы, прокси, почтовый шлюз	Из DMZ во внутренние зоны — только конкретные потоки
Гостевой Wi-Fi, IoT, камеры, принтеры	Недоверенные устройства	Только интернет или сервер управления, во внутренние зоны — нет

Принцип: «запрещено всё, что не разрешено». Для каждого правила фиксируйте в комментарии владельца, основание (номер заявки) и дату пересмотра.

Все зоны общаются только через межсетевой экран



сегментация внутреннего контура · 6 зон, 1 точка контроля

Зоны не связаны напрямую: любой поток проходит через межсетевой экран и попадает в журнал; гостевая зона ходит только наружу.

7.2. Межсетевой экран на OPNsense

1. **Interfaces → Assignments**: назначьте интерфейсы SRV, USR, MGMT (или VLAN-интерфейсы на одном физическом).
2. **Firewall → Aliases**: создайте алиасы `DC_SERVERS`, `AD_PORTS` (53, 88, 135, 389, 445, 464, 636, 3268, 49152–65535 — динамический RPC лучше сузить настройкой на DC), `ADMIN_PORTS` (22, 3389, 5985, 5986).
3. **Firewall → Rules → USR**: разрешите USR → DC_SERVERS:AD_PORTS, USR → SRV01:445/443, USR → интернет (через прокси). Последним правилом — «запретить всё» с журналированием.
4. **Администрирование**: ADMIN_PORTS к серверам разрешены только из MGMT.
5. **Журналы**: отправляйте syslog OPNsense в Wazuh (System → Settings → Logging → Remote).

На самих хостах тоже включайте межсетевой экран: **Windows Defender Firewall через GPO** (запретить входящие SMB/RDP/WinRM на рабочие станции отовсюду, кроме MGMT) и **nftables/ufw** на Linux. Это главная дешёвая защита от горизонтального перемещения.

7.3. Защита канального уровня

Угроза	Мера на коммутаторе
Чужое устройство в розетке	802.1X (сервер FreeRADIUS или PacketFence как open-source NAC), отключение неиспользуемых портов
Поддельный DHCP-сервер	DHCP snooping
ARP-спуфинг	Dynamic ARP Inspection
Переполнение таблицы MAC	Port security (лимит MAC на порт)
VLAN hopping	Отключить DTP, native VLAN — неиспользуемый

7.4. Защита от типичных атак в сети Windows

Инструмент Responder (и аналоги) за минуты собирает хэши паролей, отвечая на широковещательные запросы. Что отключить через GPO:

- **LLMNR** — Computer Configuration → Administrative Templates → Network → DNS Client → Turn off multicast name resolution = Enabled.
- **NetBIOS over TCP/IP** — через настройки DHCP или скриптом.
- **WPAD** — создать DNS-запись wpad, указывающую на ваш прокси, или отключить автообнаружение.
- **SMBv1** — удалить компонент.
- **SMB signing** — требовать на всех хостах (защита от NTLM relay).
- **LDAP signing и channel binding** — требовать на контроллерах домена.
- **NTLMv1 и LM** — запретить (Network security: LAN Manager authentication level = Send NTLMv2 response only. Refuse LM & NTLM).

7.5. Обнаружение вторжений в сети (NIDS/NSM)

- **Suricata** — IDS/IPS с сигнатурами (набор правил ET Open бесплатен). В OPNsense включается в Services → Intrusion Detection.
- **Zeek** — не ищет сигнатуры, а пишет структурированные логи всех соединений (DNS, HTTP, TLS, SMB, Kerberos). Незаменим для расследований.
- **Security Onion** — дистрибутив, объединяющий Suricata, Zeek, хранение pcap и интерфейс аналитика.
- **Как подать трафик:** SPAN/mirror-порт на коммутаторе или TAP. В лаборатории — promiscuous mode на виртуальном коммутаторе.

Что искать в трафике внутреннего контура: рабочая станция обращается по SMB/RDP к другим рабочим станциям; один хост подключается к десяткам адресов за минуту (сканирование); длинные случайные DNS-имена (туннель); регулярные соединения с одинаковым интервалом к одному внешнему адресу (маячок C2 — инструмент RITA ищет их в логах Zeek); большие исходящие объёмы ночью.

7.6. Удалённый доступ и подрядчики

- VPN только с MFA (WireGuard или OpenVPN на OPNsense + privacyIDEA для TOTP).
- Подрядчики попадают только на бастийон-сервер с записью сессий (open-source варианты: Apache Guacamole, Teleport Community, JumpServer).
- Учётные записи подрядчиков активны только на срок работ по заявке.
- Запретите самовольные AnyDesk/TeamViewer/RustDesk: блокируйте их домены на прокси и запуск через AppLocker; ловите попытки в SIEM.

Практика к Главе 7

- ☐ **Базовое.** Составьте матрицу сетевых потоков для лаборатории: источник, назначение, порт, обоснование.
- ☐ **Базовое.** Реализуйте матрицу на OPNsense. Проверьте с ATK01 через `nmmap`, что из сегмента пользователей недоступны RDP и WinRM серверов.
- ☐ **Среднее.** Запустите на ATK01 Responder в режиме анализа (`-A`), затем в обычном. На WS01 обратитесь к несуществующей шаре `\\filesrvrerr`. Зафиксируйте перехваченный хэш, затем отключите LLMNR/NBT-NS через GPO и повторите — атака должна перестать работать.
- ☐ **Среднее.** Включите Suricata на OPNsense с ET Open, просканируйте серверный сегмент с ATK01 и найдите алерты.
- ☐ **Продвинутое.** Разверните Zeek и RITA, запустите на ATK01 скрипт, который раз в 60 секунд делает `curl` к одному адресу (имитация маячка). Добейтесь, чтобы RITA обнаружила его.

Глава 8. Защита Active Directory и управление доступом

Active Directory — «ключи от королевства»: в большинстве инцидентов с шифровальщиками злоумышленник сначала получает права администратора домена, а потом через GPO распространяет шифровальщик на все машины. Защита AD — самая ценная работа защитника внутреннего контура.

8.1. Как работает AD (минимум)

- **Лес, домен, OU, группы, GPO.** Групповые политики привязываются к OU и применяются по порядку LSDOU (локальная → сайт → домен → OU).
- **Kerberos:** пользователь получает TGT у KDC (на DC), затем TGS для каждого сервиса. TGT подписан ключом учётной записи `krbtgt` — если её хэш украден, злоумышленник может выпускать любые билеты (Golden Ticket).
- **NTLM** — устаревший протокол, уязвим к pass-the-hash и relay.
- **Привилегированные группы:** Domain Admins, Enterprise Admins, Schema Admins, Administrators, Account Operators, Backup Operators, Server Operators, DnsAdmins, Group Policy Creator Owners.

8.2. Атаки на AD, которые нужно знать в лицо

Атака	ATT&CK	Суть	Защита	Обнаружение
Password spraying	T1110.003	Один популярный пароль на все учётные записи	Длинные пароли, запрет словарных, MFA	Много 4625/4771 с одного источника на разные учётные записи
Kerberoasting	T1558.003	Запрос TGS для учётных записей со SPN и офлайн-подбор пароля	gMSA или пароли 25+ символов, AES вместо RC4	4769 с шифрованием 0x17 (RC4), много TGS от одного пользователя
AS-REP Roasting	T1558.004	Учётные записи без предаутентификации	Убрать флаг DONT_REQ_PREAUTH	4768 с Pre-Auth Type 0
Дамп LSASS	T1003.001	Извлечение хэшей из памяти	Credential Guard, LSA Protection (RunAsPPL), правило ASR	Sysmon Event 10 — доступ к lsass.exe
Pass-the-Hash	T1550.002	Вход с хэшем вместо пароля	LAPS, запрет сетевого входа локальных админов, модель уровней	4624 Logon Type 3 с NTLM между рабочими станциями
DCSync	T1003.006	Имитация репликации DC для получения всех хэшей	Права Replicating Directory Changes только у DC	4662 с GUID репликации от не-DC
Golden Ticket	T1558.001	Поддельный TGT	Дважды сбросить пароль krbtgt после компрометации	Аномалии срока жизни билетов, TGS без предшествующего TGT

Атака	ATT&CK	Суть	Защита	Обнаружение
Пароли в GPP / SYSVOL	T1552.006	срassword в XML старых политик	Удалить, сменить пароли	Поиск срassword в SYSVOL
Атаки на ADCS (ESC1-ESC8)	T1649	Ошибки в шаблонах сертификатов	Аудит шаблонов (Locksmith, Certify в режиме find)	4886/4887 с необычным SAN

8.3. Инструменты аудита AD

Инструмент	Что делает
PingCastle	Отчёт о здоровье AD с оценкой риска и рекомендациями. Начинать с него
BloodHound CE + SharpHound	Граф путей атаки до Domain Admins. Защитник использует его, чтобы разрезать эти пути
Purple Knight (бесплатный, не open-source)	Проверка индикаторов компрометации AD
Locksmith	Аудит и исправление ADCS
ADRecon	Выгрузка конфигурации AD в Excel-отчёт

Запуск этих инструментов в рабочей среде — только по согласованию: SharpHound и подобные утилиты срабатывают в антивирусах и SIEM как атака.

8.4. Укрепление AD: пошаговый план

- 1. Модель уровней (tiering).** Tier 0 — DC, ADCS, серверы управления AD; Tier 1 — серверы; Tier 2 — рабочие станции. Администратор уровня 0 никогда не входит на машины уровней 1–2. Реализация: права «Deny log on locally / through RDP / from network» через GPO для групп администраторов других уровней.
- 2. Раздельные учётные записи.** У администратора: a.karimov (почта и интернет), adm-t2-a.karimov, adm-t0-a.karimov. Domain Admins — 2–3 человека, а не «весь ИТ-отдел».
- 3. Protected Users** — добавьте туда привилегированные учётные записи (запрещает NTLM, делегирование, кэширование). Сначала проверьте в лаборатории.
- 4. Windows LAPS** — уникальный случайный пароль локального администратора на каждой машине (встроен в современные Windows).

5. **Парольная политика** — длина не менее 14 символов (для админов — 20+), Fine-Grained Password Policies, блокировка после 10 неудачных попыток. Запрет словарных паролей вроде Tashkent2026! — через open-source фильтр (например, Lithnet Password Protection) с вашим списком местных слов (города, название компании, футбольные клубы).
6. **Сервисные учётные записи** — перевести на gMSA; если нельзя — пароль 25+ символов, запрет интерактивного входа.
7. **Убрать мусор:** неактивные более 90 дней учётные записи и компьютеры, пароли «бессрочно», неограниченное делегирование, лишние права на объекты (находите через BloodHound).
8. **Аудит** — включите Advanced Audit Policy по рекомендациям Microsoft для DC (Account Logon, Account Management, DS Access, Logon/Logoff, Policy Change, Privilege Use).
9. **MFA** — для VPN, бастионов и привилегированного доступа (privacyIDEA, Keycloak для веб-приложений).
10. **Резервная копия AD (System State)** — офлайн и проверенная восстановлением в лаборатории.

8.5. Приманки (honeytokens)

Дешёвый и очень эффективный способ обнаружения:

- Учётная запись-приманка с заманчивым именем (svc_backup_old) и SPN — любой запрос TGS к ней (4769) означает Kerberoasting.
- Учётная запись с «паролем» в поле описания — любая попытка входа = алерт.
- Файл Пароли_серверов.xlsx на файловом сервере с аудитом доступа (4663) или с Canarytoken (open-source версия Thinkst Canarytokens разворачивается у себя).

Практика к Главе 8

- ☐ **Базовое.** Запустите PingCastle на лабораторном домене, сохраните итоговую оценку. Исправьте 5 самых серьёзных замечаний и запустите снова — оценка должна снизиться.
- ☐ **Базовое.** Внедрите Windows LAPS для OU с рабочими станциями и проверьте, что пароль читается только нужной группой.
- ☐ **Среднее.** Соберите данные SharpHound, загрузите в BloodHound CE и найдите кратчайший путь от обычного пользователя до Domain Admins. Разрежьте его и докажите повторным сбором.

- ☐ **Среднее.** С ATK01 выполните Kerberoasting (Impacket `GetUserSPNs.py`) против лабораторного домена. Найдите события 4769 с RC4 на DC01. Переведите сервисную учётную запись на gMSA и повторите.
- ☐ **Продвинутое.** Реализуйте двухуровневую модель (Tier 0 / Tier 2) через GPO. Докажите, что учётная запись Tier 0 не может войти на WS01, а приманка из 8.5 генерирует алерт в Wazuh.

Глава 9. Защита конечных точек и харднинг

Рабочая станция — первая точка, которую захватывает атакующий. Задача главы: сделать так, чтобы вредоносный файл не запустился, а если запустился — чтобы вы это увидели за минуты.

9.1. Базовый харднинг Windows (через GPO)

Основа — **CIS Benchmark** или **Microsoft Security Baselines** (бесплатный Security Compliance Toolkit с готовыми GPO). Применяйте постепенно: сначала тестовая ОУ, потом ИТ-отдел, потом все.

Мера	От чего защищает
Пользователи без прав локального администратора	Большинство техник закрепления и дампа паролей
Блокировка макросов из интернета в Office	Фишинговые документы
AppLocker или WDAC: запуск только из Program Files и Windows	Запуск из Downloads, %TEMP%, %APPDATA%
Правила ASR в Microsoft Defender	Дочерние процессы Office, кража из LSASS, запуск обфусцированных скриптов
PowerShell: Constrained Language Mode, журналирование Script Block (4104) и Module Logging	Скрытые скрипты
Отключение автозапуска и контроль USB	Заражённые флешки, утечки
BitLocker с TPM	Кража ноутбука
Credential Guard, LSA Protection	Дамп учётных данных
Автоматические обновления (WSUS)	Известные уязвимости

Антивирус: встроенный Microsoft Defender при правильной настройке (облачная защита, Tamper Protection, ASR) — нормальная база. Для госорганов и КИИ проверьте требования к сертифицированным средствам антивирусной защиты.

9.2. Харднинг Linux

1. Минимальная установка, удалить ненужные службы (`systemctl disable --now`).
2. Автообновления безопасности: `unattended-upgrades` .
3. SSH по ключам (Глава 3), Fail2ban.
4. Межсетевой экран на хосте: только нужные порты.
5. **auditd** с набором правил (например, open-source набор Neo23x0/auditd): следит за `execve` , изменениями `/etc/passwd` , `/etc/sudoers` , `cron` .
6. AppArmor/SELinux в режиме enforce.
7. Проверка: `sudo lynis audit system` — цель Hardening index 80+.

9.3. Телеметрия: Sysmon

Sysmon (бесплатный инструмент Sysinternals) пишет детальные события, которых нет в стандартных журналах. Установка с готовой конфигурацией (SwiftOnSecurity или Olaf Hartong sysmon-modular):

```
sysmon64.exe -accepteula -i sysmonconfig.xml
```

Sysmon ID	Событие	Пример использования
1	Создание процесса (с хэшем и родителем)	winword.exe → powershell.exe
3	Сетевое соединение	rundll32.exe ходит в интернет
7	Загрузка DLL	Подмена DLL
8	CreateRemoteThread	Внедрение кода
10	Доступ к процессу	Дамп LSASS
11	Создание файла	Исполняемые файлы в %TEMP%
12-14	Реестр	Ключи Run
22	DNS-запрос	Какой процесс запросил подозрительный домен

Для Linux есть Sysmon for Linux с аналогичной логикой.

9.4. Open-source EDR/XDR и средства расследования

Инструмент	Роль
Wazuh Agent	Сбор логов, контроль целостности файлов (FIM), проверка конфигурации (SCA по CIS), инвентаризация, активное реагирование
osquery / Fleet	SQL-запросы к состоянию системы на всех хостах: <code>SELECT * FROM processes WHERE on_disk = 0;</code>
Velociraptor	Охота за угрозами и сбор артефактов с сотен машин одновременно
ClamAV	Антивирусная проверка на Linux-серверах и почтовых шлюзах

Инструмент	Роль
YARA	Правила поиска вредоносных файлов по признакам

9.5. Пример политики AppLocker «за 5 минут»

1. На DC: `gpmc.msc` → новая GPO «WS-AppLocker» → Computer Configuration → Policies → Windows Settings → Security Settings → Application Control Policies → AppLocker.
2. Executable Rules → Create Default Rules (разрешает Program Files, Windows, администраторам — всё).
3. То же для Script Rules и Packaged app Rules.
4. Enforcement → **Audit only** на 2 недели; смотрите события 8003/8006 в журнале AppLocker и добавляйте исключения.
5. Включите службу Application Identity (AppIDSvc) и переключите в **Enforce**.

Практика к Главе 9

- ☐ **Базовое.** Установите Sysmon на WS01 с конфигурацией SwiftOnSecurity. Запустите `notepad.exe` из `cmd.exe` и найдите событие ID 1 с родителем.
- ☐ **Базовое.** Запустите Lynis на SRV01, запишите Hardening index, исправьте 10 рекомендаций и повторите.
- ☐ **Среднее.** Внедрите AppLocker по 9.5. Попробуйте запустить копию `calc.exe` из папки Downloads — запуск должен блокироваться.
- ☐ **Среднее.** Включите PowerShell Script Block Logging. Запустите закодированную в Base64 команду (`powershell -enc ...`) и найдите в событии 4104 её расшифрованный текст.
- ☐ **Продвинутое.** Разверните Velociraptor сервер и клиенты. Напишите hunt, который на всех машинах находит исполняемые файлы в `C:\Users\*\AppData\Local\Temp`, созданные за последние 7 дней.

Глава 10. Мониторинг, SIEM и обнаружение атак

Защита когда-нибудь пропустит атаку — вопрос в том, заметите ли вы её через час или через полгода. SIEM собирает журналы со всех систем в одно место, коррелирует их и поднимает тревогу. В этой главе вы построите собственный мини-SOC на open-source.

10.1. Выбор open-source SIEM

Решение	Сильные стороны	Когда выбирать
Wazuh	Агенты + SIEM + готовые правила, FIM, SCA, уязвимости	Лучший старт для небольшой и средней организации
Security Onion	Сетевой мониторинг + хостовые логи + кейс-менеджмент	Нужна глубокая аналитика трафика
Graylog Open	Удобный сбор и поиск логов	Централизация логов как первый шаг
OpenSearch / ELK	Гибкость, масштаб	Есть инженеры для самостоятельной сборки

Все они разворачиваются на ваших серверах в Узбекистане, что снимает вопрос локализации персональных данных в журналах (см. 1.3).

10.2. Установка Wazuh и подключение источников

1. На SIEM01 (Ubuntu, 8 ГБ ОЗУ, 4 vCPU, 50+ ГБ диска) выполните установку all-in-one по официальной инструкции Quickstart на documentation.wazuh.com (скрипт `wazuh-install.sh -a`). Сохраните выведенный пароль admin.
2. Откройте `https://<IP SIEM01>` с админской машины из сегмента MGMT.
3. **Агенты Windows:** в интерфейсе Agents → Deploy new agent → скопируйте команду PowerShell и выполните на DC01 и WS01. Для массового развёртывания — MSI через GPO.
4. **Сбор Sysmon:** в `ossec.conf` агента добавьте:

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
<localfile>
  <location>Microsoft-Windows-PowerShell/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

5. **Агенты Linux:** аналогично, плюс сбор `/var/log/audit/audit.log`.
6. **Сетевые устройства:** syslog с OPNsense и алерты Suricata (eve.json).
7. **Проверка:** в разделе Threat Hunting должны появиться события со всех источников.

10.3. Что обязательно собирать

Источник	Приоритет	Ключевые события
Контроллеры домена	1	Входы, Kerberos, изменения групп и GPO
Межсетевые экраны, VPN	1	Входы VPN, запрещённые соединения
Рабочие станции (Sysmon, PowerShell, Defender)	1	Процессы, скрипты, алерты антивируса
Серверы с ПДн и финансами	1	Доступы, администрирование, выгрузки
DNS, прокси	2	Запросы к подозрительным доменам
Почта	2	Вложения, пересылка на внешние адреса
СУБД, приложения (1С, АБС)	2	Массовые выборки, изменение прав

Хранение: определите срок внутренним приказом с учётом требований вашего регулятора. Практический ориентир: 90 дней «горячих» данных для поиска и 12 месяцев в архиве. Доступ к SIEM — по ролям, с журналированием, ведь в логах есть персональные данные.

10.4. Правила обнаружения

Sigma — открытый формат правил, независимый от SIEM. В репозитории SigmaHQ более 3000 готовых правил; утилита `sigma-cli` конвертирует их в запросы нужного формата.

Пример Sigma-правила:

```

title: Office запускает командную оболочку
logsource:
  product: windows
  category: process_creation
detection:
  selection:
    ParentImage|endswith: ['\winword.exe', '\excel.exe', '\outlook.exe']
    Image|endswith: ['\cmd.exe', '\powershell.exe', '\wscript.exe',
'\mshta.exe']
  condition: selection
level: high
tags: [attack.execution, attack.t1204.002]

```

То же как правило Wazuh (файл `/var/ossec/etc/rules/local_rules.xml`):

```

<group name="custom,sysmon,">
  <rule id="100100" level="12">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.parentImage" type="pcre2">(?!)\(winword|excel|outlook)\.exe$</field>
    <field name="win.eventdata.image" type="pcre2">(?!)\(cmd|powershell|wscript|mshta)\.exe$</field>
    <description>Office запустил оболочку: $(win.eventdata.image)
  </description>
  <mitre><id>T1204.002</id></mitre>
  </rule>
</group>

```

После изменения: `sudo /var/ossec/bin/wazuh-logtest` для проверки, затем `systemctl restart wazuh-manager`.

10.5. Первые 15 правил для внутреннего контура

1. Добавление в привилегированные группы AD (4728/4732/4756).
2. Очистка журнала безопасности (1102).
3. Password spraying: > 10 разных учётных записей с неудачным входом с одного источника за 5 минут.
4. Kerberoasting: 4769 с RC4 или запрос к учётной записи-приманке.
5. Доступ к LSASS (Sysmon 10) не от системных процессов.
6. Office → оболочка (правило выше).
7. PowerShell с `-enc`, `IEX`, `DownloadString`, `FromBase64String`.
8. Новая служба (7045) или задача (4698) на сервере.
9. Вход администратора Tier 0 на машину не из Tier 0.

10. RDP/SMB между рабочими станциями.
11. Запуск средств удалённого доступа (AnyDesk, TeamViewer, RustDesk, ngrok).
12. Массовое переименование/изменение файлов на файловом сервере (шифровальщик), `vssadmin delete shadows`.
13. Вход VPN из необычной страны или в нерабочее время.
14. Отключение Defender или агента Wazuh.
15. Срабатывание любой приманки (honeypot).

10.6. Проверка обнаружения: Purple Teaming

Правило, которое никогда не срабатывало, может не работать. Регулярно имитируйте атаки в лаборатории и проверяйте алерты:

- **Atomic Red Team** — атомарные тесты по техникам ATT&CK (`Invoke-AtomicTest T1003.001`).
- **MITRE Caldera** — автоматизированная эмуляция цепочек атак.
- Ведите таблицу покрытия: техника → есть телеметрия? → есть правило? → проверено тестом (дата)? → раскрасьте в ATT&CK Navigator.

Запускайте атомарные тесты только в лаборатории или по письменному плану на выделенных тестовых машинах: часть тестов меняет систему.

10.7. Работа аналитика SOC L1

На каждый алерт: (1) что сработало и почему; (2) какой хост и пользователь, их критичность; (3) контекст ± 30 минут — что ещё делал хост; (4) проверка индикаторов (хэш, IP, домен) в VirusTotal, AbuseIPDB, MISP; (5) вердикт: ложное срабатывание / инцидент / нужна эскалация; (6) запись в тикет (DFIR-IRIS или TheHive). Не загружайте внутренние документы в публичные сервисы — проверяйте только хэши.

Практика к Главе 10

- ☐ **Базовое.** Установите Wazuh, подключите DC01, WS01, SRV01 и OPNsense. Сделайте 5 неудачных входов на WS01 и найдите их в Wazuh.
- ☐ **Базовое.** Включите FIM на папку `C:\Finance` и проверьте алерт при изменении файла.
- ☐ **Среднее.** Реализуйте правила 1, 2, 3, 6, 7 из 10.5 в Wazuh и проверьте каждое ручным тестом.
- ☐ **Среднее.** Установите Atomic Red Team на WS01 и выполните 10 тестов. Заполните таблицу покрытия: сколько из 10 обнаружено.

- ☐ **Продвинутое.** Сконвертируйте 20 правил из SigmaHQ для Windows в правила Wazuh, положите их в Git и настройте автоматическую проверку синтаксиса (Detection-as-Code).

Глава 11. Реагирование на инциденты и цифровая криминалистика

Когда инцидент случился, выигрывает тот, у кого есть заранее продуманный и отрепетированный план. Импровизация в 3 часа ночи стоит организации дней простоя и уничтоженных доказательств.

11.1. Жизненный цикл инцидента (NIST SP 800-61)

1. **Подготовка** — план, контакты, инструменты, резервные копии, учения.
2. **Обнаружение и анализ** — подтвердить инцидент, оценить масштаб, присвоить критичность.
3. **Сдерживание** — изолировать хосты, заблокировать учётные записи и IP, но не уничтожить следы.
4. **Устранение** — удалить закрепление, сменить пароли (включая двойной сброс krbtgt при компрометации домена), закрыть уязвимость входа.
5. **Восстановление** — вернуть системы из чистых копий, усиленный мониторинг.
6. **Разбор после инцидента** — что сработало, что нет, конкретные задачи со сроками. Без поиска виноватых.

11.2. План реагирования: что в нём должно быть

- Команда и роли: руководитель реагирования, технический аналитик, сисадмины, **юрист**, PR/коммуникации, руководство.
- Классификация инцидентов по критичности (например, низкий / средний / высокий / критический) и правила эскалации.
- **Внешние уведомления** с учётом законодательства РУз: уполномоченный орган по кибербезопасности и UZCERT; отраслевой регулятор (для банков — Центральный банк); уполномоченный орган по персональным данным при утечке ПДн; правоохранительные органы при признаках преступления. Сроки, формы и контакты впишите в план после проверки актуальных требований с юристом.
- Каналы связи на случай компрометации почты и AD (заранее созданная группа в мессенджере, бумажный список телефонов).

- Playbook’и по типам: фишинг, шифровальщик, компрометация учётной записи, утечка данных, инсайдер.

11.3. Playbook: шифровальщик (первый час)

1. **Не выключайте** заражённые машины — в памяти могут быть ключи и следы. **Отключите от сети** (кабель, порт коммутатора или изоляция через EDR).
2. Сообщите руководителю реагирования, откройте журнал инцидента (время, действие, кто).
3. Определите масштаб по SIEM: какие хосты имеют те же индикаторы, откуда пришла атака.
4. Заблокируйте скомпрометированные учётные записи, особенно привилегированные.
5. Защитите резервные копии: отключите сервер резервного копирования от домена/сети, проверьте целостность офлайн-копий.
6. Соберите доказательства (см. 11.4) с 1–2 типичных хостов и образец записки с требованием выкупа.
7. Проверьте на nomoreransom.org наличие бесплатного дешифратора.
8. Уведомите органы согласно плану. Решение о переговорах с вымогателями принимает руководство с юристом, не защитник.

11.4. Сбор доказательств

Порядок летучести (RFC 3227): сначала самое нестойкое — ОЗУ, сетевые соединения, процессы; затем диск; затем логи и архивы.

Задача	Open-source инструмент
Дамп ОЗУ Windows	WinPmem, DumpIt (бесплатная версия)
Дамп ОЗУ Linux	AVML, LiME
Анализ памяти	Volatility 3
Быстрый сбор артефактов	KAPE (бесплатен для внутреннего использования), Velociraptor (Windows.KapeFiles.Targets), UAC для Linux
Образ диска	dc3dd , ewfacquire , FTK Imager (бесплатный)
Анализ диска	Autopsy / The Sleuth Kit

Задача	Open-source инструмент
Артефакты Windows	Инструменты Eric Zimmerman (MFTECmd, EvtxECmd, PECmd, Registry Explorer), Hayabusa, Chainsaw (быстрый поиск по EVTX правилами Sigma)
Таймлайн	Plaso (log2timeline), Timesketch
Учёт кейсов	DFIR-IRIS, TheHive

Цепочка хранения (chain of custody). Для каждого доказательства фиксируйте: что, откуда, кто, когда (с часовым поясом UTC+5), хэш SHA-256, где хранится, кому передавалось. Работайте с копиями, оригинал храните опечатанным. Если дело может дойти до суда, учитывайте: формальное изъятие и экспертизу проводят уполномоченные органы согласно Уголовно-процессуальному кодексу РУз; ваша задача — сохранить следы и передать их с документами.

11.5. Анализ памяти: минимальный набор команд Volatility 3

```
vol -f mem.raw windows.info
vol -f mem.raw windows.pstree           # дерево процессов
vol -f mem.raw windows.cmdline         # командные строки
vol -f mem.raw windows.netscan         # сетевые соединения
vol -f mem.raw windows.malfind         # подозрительные области памяти
```

11.6. Учения (tabletop)

Раз в квартал проводите настольные учения на 1-2 часа: ведущий зачитывает сценарий в несколько этапов («09:15 — бухгалтер сообщает, что файлы стали .locked»), участники говорят, что делают. В конце — список пробелов в плане. Бесплатные сценарии: CISA Tabletop Exercise Packages, карточная игра Backdoors & Breaches.

Практика к Главе 11

- ☐ **Базовое.** Напишите playbook «Фишинговое письмо»: от сообщения сотрудника до удаления письма из всех ящиков и блокировки домена.
- ☐ **Базовое.** Снимите дампы ОЗУ WS01 через WinPmem, посчитайте SHA-256 и заполните форму цепочки хранения.

- ☐ **Среднее.** На WS01 имитируйте атаку: создайте задачу планировщика, запускающую PowerShell, и добавьте локального администратора. Попросите друга (или себя через неделю) найти всё только по артефактам (Hayabusa + Autoruns + Velociraptor).
- ☐ **Среднее.** Решите 2 бесплатных кейса на CyberDefenders или Blue Team Labs Online (категории Endpoint Forensics и Memory Forensics).
- ☐ **Продвинутое.** Проведите tabletop с 2–3 друзьями по сценарию «шифровальщик в пятницу вечером», напишите отчёт после инцидента (хронология, первопричина, ущерб, 5 улучшений со сроками).

Глава 12. Защита данных, персональные данные, криптография, резервирование

В конечном счёте атакующие охотятся за данными: базами клиентов, финансовыми документами, персональными данными. Эта глава — о том, как знать, где они лежат, как их зашифровать, не дать им утечь и восстановить после атаки.

12.1. Классификация информации

Пример схемы, согласованной с законодательством РУз (утверждается приказом):

Класс	Примеры	Требования
Открытая	Пресс-релизы, публичные тарифы	Целостность
Для внутреннего пользования	Внутренние инструкции	Не передавать вовне
Конфиденциальная / коммерческая тайна	Договоры, финансовая отчётность до публикации	Режим коммерческой тайны, NDA, ограниченный доступ, шифрование при передаче
Персональные данные	ФИО, ПИНФЛ, паспортные данные, телефоны клиентов и сотрудников	Закон о ПДн: согласие, локализация, регистрация баз, меры защиты

Класс	Примеры	Требования
Банковская тайна (для банков)	Счета, операции	Законодательство о банках и банковской тайне, требования ЦБ
Государственные секреты	Сведения с грифом	Только в аттестованных системах, отдельный режим — вне рамок этой книги

12.2. Поиск персональных данных в контуре

Задача — найти «теневые» копии ПДн: выгрузки в Excel на общих дисках, сканы паспортов в почте.

- Узбекистанский ПИНФЛ — 14 цифр, серия и номер паспорта/ID-карты — две латинские буквы и 7 цифр, телефоны — +998 и 9 цифр. По этим шаблонам можно искать:

```
grep -rEl '\b[A-Z]{2}[0-9]{7}\b|\b[0-9]{14}\b|\+998[0-9]{9}' /srv/share
2>/dev/null
```

- Инструменты: `ripgrep` (быстрый поиск), Microsoft Presidio (open-source обнаружение и маскирование ПДн с собственными распознавателями), для Office-файлов — предварительно извлеките текст (Apache Tika).
- Результаты поиска сами по себе содержат ПДн — храните отчёт только со списком файлов, без самих значений.

12.3. Предотвращение утечек (DLP) средствами open-source

Полноценных open-source DLP-систем уровня коммерческих немного, но большую часть риска закрывает комбинация мер:

Канал утечки	Мера
USB-накопители	GPO: запрет записи на съёмные носители, белый список устройств по ID; на Linux — USBGuard
Облачные хранилища, личная почта, файлообменники	Фильтрация на прокси (Squid + SquidGuard / e2guardian), категории DNS-фильтрации

Канал утечки	Мера
Мессенджеры	Корпоративный self-hosted мессенджер (Mattermost, Rocket.Chat, Matrix/Element) + политика, запрещающая рабочие файлы в личных чатах
Почта	Правила на почтовом шлюзе (Rspamd): предупреждение/блокировка писем с шаблонами ПДн на внешние адреса
Массовые выгрузки из БД	Аудит СУБД (pgAudit для PostgreSQL), алерты в SIEM на необычные объёмы
Файловые серверы	Аудит доступа (4663), права по принципу необходимости, приманки

Любой контроль содержимого переписки сотрудников — только при наличии локального акта и уведомления сотрудников (см. 1.4).

12.4. Криптография для защитника

- **Симметричное шифрование** (AES-256-GCM) — один ключ для шифрования и расшифровки. **Асимметричное** (RSA, ECC) — пара открытый/закрытый ключ. **Хэши** (SHA-256) — контроль целостности. Пароли хранятся только солёными медленными хэшами (Argon2, bcrypt).
- **Внутренний PKI**: удостоверяющий центр для внутренних сервисов (ADCS или open-source step-ca, EJBCA Community). Все внутренние веб-интерфейсы — только HTTPS, LDAP — LDAPS.
- **Шифрование дисков**: BitLocker (Windows), LUKS (Linux); ключи восстановления — в AD или сейфе.
- **Хранение секретов**: корпоративный менеджер паролей (Vaultwarden — self-hosted Bitwarden, KeePassXC для личного использования), для сервисов — OpenBao / HashiCorp Vault.
- **Проверка TLS**: `testssl.sh https://intranet.lab.local` — запретите TLS 1.0/1.1 и слабые шифры.
- **Юридический аспект (см. 1.5)**: в коммерческих организациях стандартные встроенные средства шифрования — обычная практика; для госорганов, КИИ и юридически значимого ЭДО требуются сертифицированные СКЗИ и ЭЦП аккредитованных удостоверяющих центров РУз.

12.5. Резервное копирование — последняя линия обороны

Правило 3-2-1-1-0: 3 копии, на 2 разных носителях, 1 вне офиса (в пределах Узбекистана, если там ПДн), 1 офлайн или неизменяемая (immutable), 0 ошибок при проверке восстановления.

Инструмент	Для чего
Bareos / Bacula	Корпоративное резервное копирование серверов
Proxmox Backup Server	Резервные копии ВМ с дедупликацией и шифрованием
restic / BorgBackup	Шифрованные инкрементные копии файлов
MinIO с Object Lock	Неизменяемое хранилище для копий

Защита самих бэкапов: сервер резервного копирования не в домене (или в отдельном домене), свои учётные записи с MFA, отдельный сегмент сети. Шифровальщики целенаправленно ищут и уничтожают бэкапы.

Восстановление тестируется ежеквартально с замером времени (RTO) и объёма потерянных данных (RPO).

Практика к Главе 12

- ☐ **Базовое.** Сгенерируйте с помощью Faker 500 выдуманных записей клиентов (ФИО, ПИНФЛ-подобный номер, телефон +998), разложите файлы на шаре SRV01 и найдите их поиском из 12.2.
- ☐ **Базовое.** Включите BitLocker на WS01 с сохранением ключа восстановления в AD; убедитесь, что ключ виден в карточке компьютера.
- ☐ **Среднее.** Настройте restic-бэкап шары SRV01 в MinIO с Object Lock. Удалите данные на SRV01, восстановите и запишите фактические RTO/RPO.
- ☐ **Среднее.** Запретите запись на USB для OU «Бухгалтерия» и настройте алерт в Wazuh на подключение USB-накопителя.
- ☐ **Продвинутое.** Напишите собственный распознаватель Presidio для узбекистанских ПИНФЛ и номеров паспортов и прогоните его по тестовым данным; посчитайте долю ложных срабатываний.

Глава 13. Документы, политики, аудит и соответствие

Техническая мера без документа не существует для аудитора, регулятора и суда. В Узбекистане локальные акты вступают в силу приказом руководителя, а сотрудники должны быть ознакомлены с ними под подпись — иначе нарушение политики нельзя предъявить работнику.

13.1. Минимальный пакет документов ИБ

Документ	Уровень	Кто утверждает
Политика информационной безопасности (2–5 стр.)	Стратегический	Руководитель организации
Положение о подразделении ИБ / ответственном лице	Организационный	Руководитель
Политика допустимого использования ИТ-ресурсов	Для всех сотрудников	Руководитель, ознакомление под подпись
Положение об обработке и защите персональных данных	По требованию Закона о ПДн	Руководитель
Перечень сведений, составляющих коммерческую тайну	По Закону о коммерческой тайне	Руководитель
Политика управления доступом и паролями	Технический	Руководитель ИТ/ИБ
Регламент управления уязвимостями и обновлениями	Технический	Руководитель ИТ/ИБ
Регламент журналирования и мониторинга	Технический	Руководитель ИТ/ИБ
План реагирования на инциденты	Операционный	Руководитель
План обеспечения непрерывности и восстановления	Операционный	Руководитель

Документ	Уровень	Кто утверждает
Реестр активов и реестр рисков	Рабочие записи	Ответственный за ИБ
Обязательство о неразглашении (для сотрудников и подрядчиков)	Индивидуальный	Подписывает каждый

Правила хорошего документа: конкретные действия вместо деклараций; владелец и дата пересмотра (не реже раза в год); ссылки на нормы законодательства РУз; язык — государственный (узбекский) с переводом на русский при необходимости, в соответствии с Законом «О государственном языке» и практикой вашей организации.

Бесплатные шаблоны для адаптации: SANS Information Security Policy Templates, шаблоны CIS. Их нужно переработать под реалии и нормы Узбекистана, а не переводить дословно.

13.2. Система менеджмента ИБ по ISO/IEC 27001

Цикл PDCA: **планирование** (область, политика, оценка рисков, Ведомость применимости — Statement of Applicability) → **внедрение** мер → **проверка** (внутренний аудит, метрики, анализ руководством) → **улучшение** (корректирующие действия). 93 меры Annex A (редакция 2022) сгруппированы в четыре темы: организационные, кадровые, физические и технологические.

Инструменты GRC на open-source: **CISO Assistant** (оценка соответствия ISO 27001, NIST CSF, CIS и др.), **Eramba Community**, **SimpleRisk Core**.

13.3. Аудит собственной защиты

- **Внутренний аудит** — проверка по чек-листу (CIS Controls IG1, собственные политики) с доказательствами: скриншоты, выгрузки, отчёты Wazuh SCA, PingCastle, Lynis.
- **Внешний аудит и тест на проникновение** — для КИИ и ряда отраслей проводится организациями, имеющими необходимые лицензии/аккредитацию (например, Центр кибербезопасности или лицензированные компании). Задача внутреннего защитника — подготовить документы, согласовать область работ и устранить замечания.

13.4. Метрики для руководства

Руководству нужно понять три вещи: защищены ли мы, стало ли лучше, что нужно решить. Ежемесячный отчёт на 1 страницу:

Метрика	Цель (пример)
Доля хостов с агентом SIEM/EDR	≥ 98%
Доля активов под сканированием уязвимостей	≥ 95%
Просроченные уязвимости P1/P2	0
Среднее время обнаружения (MTTD) и реагирования (MTTR)	Снижается квартал к кварталу
Число учётных записей в Domain Admins	≤ 3
Доля сотрудников, нажавших на учебный фишинг	Снижается; доля сообщивших — растёт
Успешные тесты восстановления из бэкапа	100% запланированных
Покрытие техник АТТ&СК проверенными правилами	Растёт

13.5. Обучение сотрудников

- Вводный инструктаж по ИБ при приёме на работу и ежегодный повторный (короткие видео на узбекском и русском).
- Учебные фишинговые рассылки на open-source **GoPhish** — только с письменного разрешения руководства, по согласованию с HR и юристом; без сбора настоящих паролей и без использования брендов госорганов и чужих компаний.
- Простой канал «сообщить о подозрительном» (кнопка в почте, адрес security@) и благодарность тем, кто сообщает.

Практика к Главе 13

- ☐ **Базовое.** Напишите Политику ИБ для «ООО Учебный Банк» на 3 страницы: цели, область, роли, принципы, ответственность, ссылки на законы РУз.

- ☐ **Базовое.** Составьте Ведомость применимости для 20 мер ISO/IEC 27001 Annex A: применимо (да/нет), обоснование, статус внедрения в лаборатории.
- ☐ **Среднее.** Разверните CISO Assistant и проведите самооценку лаборатории по CIS Controls IG1.
- ☐ **Среднее.** Подготовьте одностраничный отчёт для руководства по метрикам 13.4 на данных лаборатории.
- ☐ **Продвинутое.** В лаборатории проведите учебную фишинговую кампанию GoPhish на тестовые почтовые ящики (например, с локальным MailHog), составьте отчёт и план обучения.

Глава 14. Карьера в Узбекистане и план на 12 месяцев

После года занятий по этой книге вы готовы к позициям младшего уровня. Главное конкурентное преимущество — не сертификаты, а портфолио с доказанной практикой и знание местных требований.

14.1. Кто нанимает защитников в Узбекистане

- **Банки и платёжные системы** — самый зрелый рынок: требования Центрального банка, собственные SOC, высокие стандарты.
- **Телеком-операторы и провайдеры.**
- **Государственные органы и предприятия**, ГУП «Центр кибербезопасности», объекты КИИ (энергетика, нефтегаз, транспорт). Для ряда должностей требуется проверка и допуск.
- **ИТ-компании и резиденты IT Park**, интеграторы и MSSP (компании, оказывающие услуги SOC другим).
- **Крупный ритейл, e-commerce, финтех** — растущий спрос.
- **Удалённая работа на международные компании** — требует английского на уровне B2+.

Где искать вакансии: hh.uz, LinkedIn, Telegram-каналы ИТ-вакансий Узбекистана, сайты банков (раздел «Карьера»).

14.2. Карьерная лестница

Уровень	Роль	Что умеет
Старт	Сисадмин / техподдержка с фокусом на ИБ	Главы 1–5

Уровень	Роль	Что умеет
Junior	Аналитик SOC L1, младший инженер ИБ	Триаж алертов, базовый харднинг, сканирование (главы 1–13)
Middle	SOC L2, инженер по обнаружению, инженер защиты инфраструктуры	Расследования, написание правил, внедрение средств защиты, защита AD
Senior	SOC L3, DFIR, threat hunter, архитектор ИБ	Руководство реагированием, проектирование защиты
Lead	Руководитель SOC / ИБ, CISO	Стратегия, риски, бюджет, взаимодействие с регуляторами

14.3. Сертификации: что и в каком порядке

Этап	Сертификация	Зачем
Бесплатно	ISC2 Certified in Cybersecurity (CC), Cisco «Introduction to Cybersecurity», Fortinet NSE 1–3	Первая строчка в резюме
База	CompTIA Security+, Cisco CCNA или CyberOps Associate	Широко признаются работодателями
Практика Blue Team	BTL1 (Security Blue Team), CyberDefenders CCD, TryHackMe SOC Level 1	Доказывают практические навыки
Специализация	GIAC GCIN/GCIA/GCFA, Microsoft SC-200	Переход на уровень Middle+
Менеджмент	ISO/IEC 27001 Lead Implementer / Lead Auditor, CISSP, CISM	Руководящие роли, госсектор и банки

Местное образование: профильные направления по ИБ в ТУИТ им. Мухаммада аль-Хорезми и других вузах, программы IT Park и платформы вроде «One Million Uzbek Coders» — актуальный список курсов проверяйте на их сайтах.

Участвуйте в CTF-соревнованиях и местных ИБ-сообществах — там находятся первые работодатели.

14.4. Портфолио

Публичный GitHub-репозиторий «мой SOC-стенд»:

- схема лаборатории и код её развёртывания (Глава 5);
- ваши правила Wazuh/Sigma с привязкой к АТТ&СК и описанием тестов (Глава 10);
- 2–3 отчёта о расследованиях учебных кейсов (Глава 11);
- скрипты автоматизации на Python/PowerShell;
- шаблоны политик ИБ, адаптированные под законодательство РУз (Глава 13);
- статьи в блоге или Telegram-канале на узбекском/русском — сильно выделяют на местном рынке.

Никогда не публикуйте данные, конфигурации или логи реальных работодателей — это нарушение NDA и, возможно, закона о коммерческой тайне и ПДн.

14.5. Собеседование SOC L1: типичные вопросы

1. Чем отличается TCP от UDP? Какие порты у Kerberos, LDAP, SMB, RDP?
2. Что происходит, когда пользователь вводит пароль в доменном Windows?
3. События 4624 и 4625: что такое Logon Type 3 и 10?
4. Пришёл алерт «powershell.exe запущен winword.exe». Ваши действия по шагам?
5. Что такое Kerberoasting и как его обнаружить?
6. Чем IDS отличается от IPS, а SIEM от EDR?
7. Что такое MITRE ATT&CK? Назовите 3 тактики.
8. Какие законы РУз регулируют ИБ и защиту ПДн? Что такое локализация?
9. Ваши первые действия при обнаружении шифровальщика?
10. Расскажите о проекте в вашей лаборатории, которым вы гордитесь.

14.6. План по неделям (10–15 часов в неделю)

Недели	Фокус	Итог для портфолио
1–2	Глава 1, английский для ИТ (ежедневно 30 мин)	Конспект законов, шаблон разрешения
3–6	Глава 2, Cisco Networking Basics	Разбор pcap, схема VLAN в GNS3
7–14	Глава 3, Bandit, Python	Скрипты triage.sh и анализа auth.log
15–17	Глава 4, подготовка к ISC2 CC	Реестр рисков, сертификат CC
18–20	Глава 5	Лаборатория как код

Недели	Фокус	Итог для портфолио
21–24	Глава 6	Отчёт об уязвимостях с приоритизацией
25–28	Глава 7	Матрица потоков, Suricata/Zeek
29–32	Глава 8	Отчёт PingCastle «до/после»
33–36	Глава 9, начало подготовки к Security+	Харднинг + Sysmon + Velociraptor
37–41	Глава 10	Репозиторий правил, карта покрытия АТТ&СК
42–45	Глава 11	2 отчёта о расследованиях
46–49	Главы 12–13	Пакет политик, бэкапы с RTO/RPO
50–52	Итоговый проект, Security+, резюме, отклики	Готовое портфолио

Практика к Главе 14

- ☐ **Базовое.** Найдите 10 актуальных вакансий ИБ в Узбекистане и выпишите часто встречающиеся требования. Сравните со своими навыками.
- ☐ **Базовое.** Ответьте письменно на 10 вопросов из 14.5, затем вслух за 2 минуты на каждый.
- ☐ **Среднее.** Оформите GitHub-портфолио по 14.4 с README на двух языках.
- ☐ **Продвинутое.** Проведите для небольшой знакомой организации бесплатную самооценку по CIS Controls IG1 **с письменным разрешением руководителя** (только интервью и просмотр настроек, без атакующих тестов). Составьте отчёт с 10 рекомендациями.

Приложения

Приложение А. Итоговый проект «Защита ООО Учебный Банк»

Вы — единственный специалист по ИБ в организации из 100 сотрудников. За 4 недели в своей лаборатории выполните:

1. Реестр активов в GLPI и реестр из 15 рисков.
2. Сегментация на 4 зоны с матрицей потоков и правилами OPNsense.

3. Укрепление AD: оценка PingCastle снижена не менее чем вдвое, LAPS, tiering, gMSA, приманки.
4. Харднинг рабочих станций (AppLocker, ASR, журналирование PowerShell, BitLocker) и серверов (Lynis ≥ 80).
5. Wazuh с агентами на всех хостах, Sysmon, 15 правил из 10.5, карта покрытия АТТ&СК.
6. Сканирование уязвимостей, устранение всех P1/P2.
7. Бэкапы по 3-2-1-1-0 с проверенным восстановлением.
8. **Финальный тест:** друг или наставник с ATK01 проводит цепочку атаки (Responder → password spraying → Kerberoasting → горизонтальное перемещение → имитация шифрования) без предупреждения о времени. Вы обнаруживаете, сдерживаете и пишете отчёт об инциденте.
9. Пакет документов из 13.1 (минимум 6 документов) и отчёт для руководства.

Критерии оценки (100 баллов):

Критерий	Баллы
Атака обнаружена на первых трёх шагах	25
Атакующий не получил права Domain Admin	20
Качество отчёта об инциденте (хронология, первопричина, АТТ&СК)	20
Восстановление из бэкапа уложилось в целевое RTO	15
Документы и соответствие законодательству РУз	10
Автоматизация (код в Git)	10

Приложение Б. Шпаргалка защитника

Windows: быстрый триаж хоста

```
Get-Process | Sort-Object CPU -Descending | Select -First 15 Name,Id,Path
Get-NetTCPConnection -State Established | Select
LocalPort,RemoteAddress,RemotePort,OwningProcess
Get-ScheduledTask | Where-Object {$_.Date -gt (Get-Date).AddDays(-7)}
Get-CimInstance Win32_Service | Where-Object {$_.PathName -match
'Temp|AppData|ProgramData'}
Get-LocalGroupMember Administrators
Get-ItemProperty HKLM:\Software\Microsoft\Windows\CurrentVersion\Run,
HKCU:\Software\Microsoft\Windows\CurrentVersion\Run
```

Linux: быстрый триаж хоста

```
w; last -n 20; ss -tulpn; ps auxf --sort=-%cpu | head -20
awk -F: '$3==0' /etc/passwd
for u in $(cut -d: -f1 /etc/passwd); do crontab -l -u "$u" 2>/dev/null | sed
"s/^/$u: /"; done
find / -xdev -newer /etc/hostname -type f -perm -u+x 2>/dev/null | head
systemctl list-timers --all
```

AD: быстрые проверки

```
Get-ADGroupMember "Domain Admins" -Recursive | Select Name
Get-ADUser -Filter {ServicePrincipalName -like "*"} -Properties
ServicePrincipalName
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true}
Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00 -UsersOnly
Get-ADUser -Filter {PasswordNeverExpires -eq $true}
```

Приложение В. Ключи и подсказки к заданиям

Задание	Ключ / подсказка
2, подсети	10.20.30.0/26: сеть 10.20.30.0, broadcast 10.20.30.63, 62 хоста. 192.168.10.0/24 на 4 части: /26 — .0, .64, .128, .192
2, SNI	SNI передаётся до установления шифрования, чтобы сервер выбрал сертификат; фильтр Wireshark tls.handshake.extensions_server_name
3, удачный подбор	Сгруппируйте по IP: счётчик строк «Failed password» и флаг наличия «Accepted» после последней неудачи

Задание	Ключ / подсказка
3, 4688	GPO: Audit Process Creation + «Include command line in process creation events» в Administrative Templates → System → Audit Process Creation
4, ATT&CK	Пример: шаг 4 — Credential Access (TA0006): T1003.001, T1558.003
7, Responder	До исправления получите хэш NTLMv2; после отключения LLMNR и NBT-NS запросов в эфире не будет — проверьте в Wireshark фильтром `llmnr`
8, Kerberoasting	В событии 4769 поле Ticket Encryption Type = 0x17 (RC4). После перехода на gMSA пароль 240 байт и подбор становится невозможным
9, PowerShell -enc	Событие 4104 в Microsoft-Windows-PowerShell/Operational содержит уже декодированный ScriptBlockText
10, spraying	В Wazuh: правило с <code>frequency</code> , <code>timeframe</code> и <code>different_field</code> (или <code>different_srcuser</code>) поверх базового правила 4625
12, RTO	RTO — время от начала восстановления до работы сервиса; RPO — возраст последней копии на момент сбоя

Приложение Г. Ресурсы

Нормативная база РУз: lex.uz — актуальные тексты законов; uzcert.uz — национальный CERT, бюллетени и сообщения об инцидентах.

Справочники и фреймворки: [MITRE ATT&CK](https://attack.mitre.org/), [MITRE D3FEND](https://d3fend.mitre.org/), [CIS Controls](https://cisecurity.org/), [NIST CSF](https://nist.gov/), [CISA KEV](https://cisa.gov/).

Инструменты (open-source):

Категория	Инструменты
Виртуализация	Proxmox VE, VirtualBox, KVM
Сеть	OPNsense, Suricata, Zeek, Security Onion, RITA, Wireshark, Nmap
SIEM / XDR	Wazuh, Graylog, OpenSearch

Категория	Инструменты
Конечные точки	Sysmon, osquery, Velociraptor, ClamAV, YARA, Lynis
Уязвимости	Greenbone/OpenVAS, Nuclei, Trivy, DefectDojo
AD	PingCastle, BloodHound CE, Locksmith
Инциденты и криминалистика	Volatility 3, Autopsy, Plaso, Timesketch, Hayabusa, Chainsaw, DFIR-IRIS, TheHive
Purple Team	Atomic Red Team, MITRE Caldera
Данные и доступ	Vaultwarden, privacyIDEA, Keycloak, Presidio, restic, Bareos, MinIO
GRC и обучение	CISO Assistant, GoPhish, GLPI

Практика онлайн: TryHackMe, Blue Team Labs Online, CyberDefenders, LetsDefend, OverTheWire, malware-traffic-analysis.net.

Книги: «Blue Team Handbook» (D. Murdoch), «Practical Threat Intelligence and Data-Driven Threat Hunting» (V. Roccia), «The Practice of Network Security Monitoring» (R. Bejtlich), «Intelligence-Driven Incident Response» (S. Roberts, R. Brown).

И последнее: защитник учится всю жизнь. Выделяйте 2 часа в неделю на чтение отчётов об инцидентах (The DFIR Report, блоги вендоров) и следите за изменениями законодательства Узбекистана на lex.uz.